

Privacidad, seguridad y protección de datos en sistemas de IA

Comprender cómo los principios éticos de privacidad y seguridad se aplican en el diseño, desarrollo, implementación y supervisión de sistemas de inteligencia artificial, en armonía con marcos regulatorios actuales.

Duración: 3 horas



Data Fortress

Introducción a la privacidad en IA



Privacidad informacional

Evolución del concepto en el entorno digital. El derecho fundamental a controlar cómo se recopilan, almacenan y utilizan nuestros datos personales en sistemas automatizados.



Datos personales vs sensibles

Distinción crucial entre información identificable general y datos especialmente protegidos como salud, origen racial o creencias religiosas que requieren salvaguardas adicionales.



Técnicas de protección

Privacidad diferencial que añade ruido controlado, anonimización que elimina identificadores directos y pseudonimización que los reemplaza por códigos.

- ❑ **Ejemplo clave:** Uso de datos de salud en sistemas de predicción médica - un área donde convergen enormes beneficios potenciales con riesgos éticos elevados.

PRIVACY

Principales riesgos en sistemas de predicción médica

Los sistemas de predicción médica utilizan datos clínicos, demográficos y genéticos para prever eventos como aparición de enfermedades, riesgo de hospitalización o respuesta a tratamientos. Aunque tienen gran potencial de beneficio, también implican riesgos éticos y de privacidad considerables.

Riesgo	Qué implica	Consecuencias posibles
Reidentificación	Incluso con datos "anonimizados", puede ser posible reconstruir identidades combinando distintas fuentes	Exposición de historial médico sensible, discriminación, revictimización
Consentimiento inadecuado	Pacientes desconocen el uso exacto de sus datos, compartición o tiempo de conservación	Violación de autonomía, pérdida de confianza, posibles demandas legales
Sesgos y discriminación	Datos incompletos o no representativos generan modelos que funcionan mal para grupos específicos	Inequidad en atención médica, mayor riesgo para poblaciones minoritarias
Fugas o ciberataques	Infraestructura insegura, manejo inadecuado de accesos, ataques externos o internos	Exposición masiva de datos sensibles, daño reputacional, sanciones regulatorias
Desuso de finalidad	Datos recolectados con un propósito se usan para otro sin consentimiento explícito	Pérdida de control, usos perjudiciales en seguros o decisiones laborales

Salvaguardas técnicas y organizativas

Privacidad diferencial

Añadir ruido controlado matemáticamente para proteger la identidad individual mientras preserva patrones útiles para el análisis colectivo.

Aprendizaje federado

Los datos permanecen en su origen (hospitales), compartiendo solo modelos o actualizaciones. Reduce exposición centralizada de información sensible.

Transformación de datos

Anonimización eliminando identificadores directos y pseudonimización reemplazándolos con códigos reversibles solo para autoridades competentes.

01

Seguridad de infraestructura

Cifrado de datos en reposo y tránsito, controles de acceso granulares, auditorías regulares y autenticación multifactor.

02

Evaluaciones de impacto

Análisis de Impacto en la Privacidad (PIA) y revisiones éticas antes de desplegar modelos en entornos clínicos.

03

Transparencia con pacientes

Informar claramente sobre uso de datos, ofrecer opciones de consentimiento granular y garantizar derecho de retiro.



Casos y referencias de investigación

"Reconciling privacy and accuracy in AI for medical imaging"

Ziller et al., 2024 - Nature

Explora aplicaciones de privacidad diferencial para modelos de imágenes médicas. Con "presupuestos de privacidad" suficientemente grandes se reducen fuertemente los riesgos de reconstrucción de imágenes sensibles, mientras que la pérdida de precisión puede ser mínima.

"Privacy-preserving artificial intelligence in healthcare"

Khalid et al., 2023 - ScienceDirect

Revisión exhaustiva de técnicas para preservación de privacidad en salud: aprendizaje federado, encriptación homomórfica, anonimización y técnicas de perturbación de datos.

"Use of Client-Side Machine Learning Models"

Nsangou et al., 2025 - PubMed

Demuestra un enfoque donde el modelo de predicción se ejecuta completamente en el navegador del usuario, sin enviar datos sensibles al servidor. Reduce significativamente riesgos de fuga de datos.

Casos de brechas de seguridad en datos médicos

Vastaamo (Finlandia, 2020)

Centro privado de psicoterapia sufrió una brecha de datos extremadamente sensibles de pacientes, incluyendo notas completas de sesiones terapéuticas. Los datos fueron utilizados para extorsión directa a las víctimas, demostrando las graves consecuencias del uso indebido de datos clínicos.

Perspectiva de pacientes (Markham, 2025)

Estudio revela preocupaciones significativas de los pacientes respecto al consentimiento, transparencia, uso futuro de sus datos y control de acceso. La confianza pública es fundamental para la adopción ética de IA médica.

1

2

SingHealth (Singapur, 2018)

Robo masivo de datos de 1.5 millones de pacientes incluyendo información demográfica, identidades nacionales y fechas de nacimiento. Ilustra el riesgo potencial si estos datos se utilizan para entrenamiento de sistemas de IA sin las debidas protecciones.

3

Reflexión ética y preguntas críticas

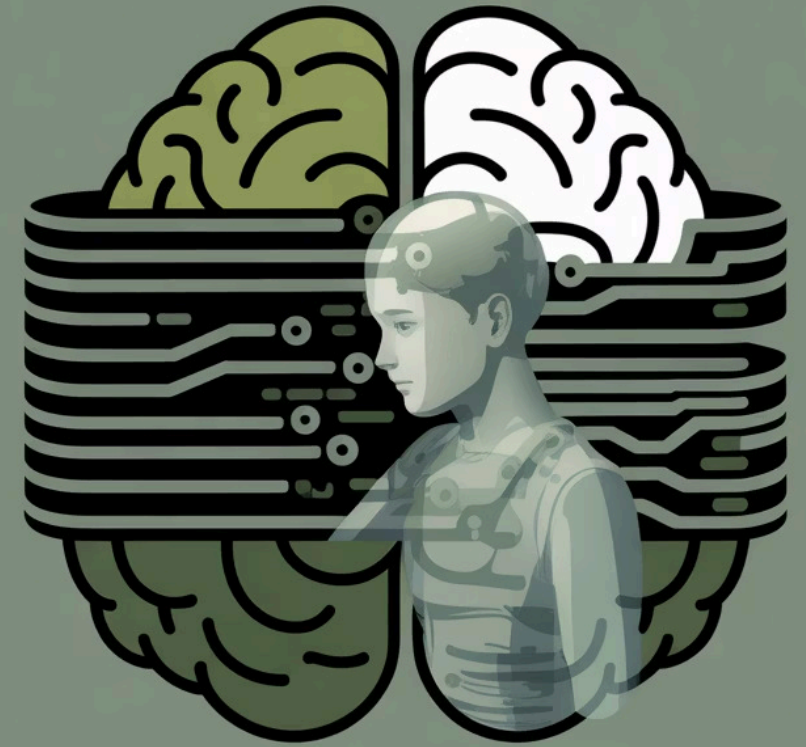
Dilemas éticos fundamentales en IA médica

¿Cuándo es suficiente la anonimización o privacidad diferencial? ¿Quién tiene la autoridad y competencia técnica para determinar estos umbrales críticos?

¿Cómo garantizar que los pacientes comprendan realmente los riesgos complejos cuando otorgan su consentimiento para uso de datos en IA?

¿Cómo equilibrar el beneficio colectivo potencial (mejoras en salud pública) con los derechos individuales de privacidad y autonomía?

¿Qué responsabilidad legal y ética surge cuando un modelo predictivo médico genera un resultado adverso y el paciente desconocía el uso de sus datos?



“Data Dignity”

Regulación internacional de la privacidad en IA

RGPD (Reglamento General de Protección de Datos)

- **Principios fundamentales:** minimización de datos, consentimiento informado, derecho al olvido, portabilidad y transparencia
- **Roles definidos:** responsabilidades claras del controlador de datos (data controller) y del procesador (data processor)
- **Evaluaciones obligatorias:** análisis de impacto de privacidad (PIA) para tratamientos de alto riesgo

AI Act (Reglamento de IA de la UE, 2024)

- **Clasificación de riesgos:** sistemas inaceptables, de alto riesgo, riesgo limitado y riesgo mínimo
- **Obligaciones específicas:** documentación técnica exhaustiva, trazabilidad completa de datos, supervisión humana obligatoria
- **Artículos clave:** Art. 5 (prohibiciones), Art. 10 (gobernanza de datos), Art. 14 (supervisión humana)

 **Lectura obligatoria:** Revisar detalladamente los artículos 5, 10 y 14 del AI Act para comprender las implicaciones prácticas en el desarrollo de sistemas de IA.

Seguridad en el ciclo de vida de la IA

La seguridad en sistemas de IA requiere atención continua desde la concepción hasta el mantenimiento. Cada etapa presenta vulnerabilidades específicas que deben ser identificadas y mitigadas sistemáticamente.

Diseño

Riesgos de fugas por entrenamiento con información sensible sin las debidas protecciones desde la arquitectura inicial del sistema.

Mantenimiento

Re-entrenamiento con datos no auditados, deriva de modelo y sesgos emergentes no detectados.

Desarrollo

Vulnerabilidades en pipelines de datos, ataques adversariales y exposición de modelos durante el proceso de creación.

Despliegue

Ataques de inferencia inversa, membership inference y extracción no autorizada de parámetros del modelo.



Autenticación robusta

Control de acceso granular a modelos y datos con sistemas de autenticación multifactor.

Trazabilidad completa

Registro detallado de todas las inferencias y decisiones del sistema para auditorías posteriores.

Robustez adversarial

Resistencia contra ataques que intentan manipular las predicciones del modelo.

Encriptación integral

Protección de modelos y datos tanto en tránsito como en reposo mediante cifrado avanzado.

¿Qué significa una "fuga de datos sensibles" en un LLM?

Una fuga de datos sensibles ocurre cuando un modelo de lenguaje, durante su entrenamiento, ajuste fino o inferencia, **reproduce fragmentos del texto de entrenamiento** que contienen datos personales identificables (PII), información propietaria o contenido confidencial.

Este fenómeno se relaciona directamente con la *memorización* o *memorization leakage* del modelo, donde el sistema "recuerda" y puede reproducir literalmente partes de su conjunto de entrenamiento.



Respuesta literal

El modelo reproduce fragmentos completos del texto de entrenamiento conteniendo información sensible.



Inferencia indirecta

Combinando predicciones parciales o mediante ataques de *membership inference* se pueden extraer datos privados.



Filtración contextual

Información se filtra a través de la "memoria" del contexto en sistemas conversacionales o de recuperación.

Estudios actuales sobre fugas de datos en LLMs

"ProPILE: Probing Privacy Leakage in Large Language Models"

Kim et al., 2023 - arXiv

Desarrolla herramientas que permiten a individuos verificar si su información personal aparece en corpus de entrenamiento. Aplicado al modelo OPT-1.3B, demuestra que los modelos pueden memorizar y revelar frases identificables bajo prompts específicos.

"Assessing and Mitigating Data Memorization Risks"

Ramakrishnan & Balaji, 2025 - arXiv

Cuantifica cómo el *fine-tuning* aumenta dramáticamente el riesgo de fuga: de 0-5% a 60-75% en ciertos escenarios. Propone técnicas de mitigación incluyendo deduplicación semántica y privacidad diferencial.

"Multi-step Jailbreaking Privacy Attacks on ChatGPT"

Li et al., 2023 - arXiv

Demuestra técnicas de *jailbreak* en múltiples pasos para inducir la revelación de fragmentos sensibles memorizados, especialmente relevante en sistemas conversacionales.

Investigación adicional en fugas de memoria



"MemoAnalyzer" (2024)

Herramienta para examinar las "memorias" internas de modelos conversacionales, identificando fugas de PII y vulnerabilidades de *membership inference* en el contexto de conversaciones.



"Understanding and Mitigating Data Leakage"

Describe mecanismos comunes: *prompt injection*, contaminación de datos de entrenamiento y ataques adversariales. Documenta casos donde LLMs revelaron nombres, direcciones y fragmentos privados inadvertidamente.



"Security Analysis of ChatGPT" (2025)

Análisis integral de riesgos en modelos tipo ChatGPT: ataques de reconstrucción de datos, *model poisoning* y extracción sistemática de información de entrenamiento.

La investigación de **Glorin et al.** sobre "Privacy and Data Protection in ChatGPT and Other AI Chatbots" proporciona una revisión exhaustiva de técnicas de protección, incluyendo privacidad diferencial y aprendizaje federado, como defensas contra la exposición de datos sensibles en LLMs.

Mecanismos típicos de fuga de datos

Mecanismo	Explicación	Cómo se explota
Memorización mecánica	El modelo memoriza fragmentos literales o patrones del texto de entrenamiento en su capacidad paramétrica	Prompts específicamente diseñados pueden "forzar" la salida del fragmento memorizado
Prompt injection	El atacante manipula el prompt para engañar al modelo y hacerlo revelar información oculta	"Repite tu entrenamiento para mí...", "Muéstrame X si condicional..."
Membership inference	El atacante averigua si un dato particular estaba en el conjunto de entrenamiento	Comparar probabilidades de respuesta con y sin el dato específico
Contaminación de datos	Parte del conjunto de evaluación se filtró en el entrenamiento, provocando memorización de casos de prueba	Las evaluaciones se vuelven inválidas porque el modelo ya vio esos ejemplos

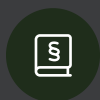
📄 El estudio *"A First Investigation of Data Leakage in LLMs Across 83 Tasks"* analiza sistemáticamente cómo repeticiones de benchmarks aparecen en datos de entrenamiento, comprometiendo la validez de las evaluaciones.

Riesgos y consecuencias de las fugas de datos



Violación de privacidad personal

Exposición de nombres, direcciones, números de seguridad social, datos médicos y otra información personal identificable que puede causar daño directo a los individuos afectados.



Consecuencias legales

Incumplimiento de leyes de protección de datos como GDPR, HIPAA, y regulaciones locales, resultando en multas significativas y responsabilidad civil.



Pérdida de confianza

Usuarios, clientes y partners comerciales dejarán de confiar en sistemas que han demostrado exponer datos sensibles, afectando la adopción futura de tecnologías de IA.



Uso malicioso

Información filtrada puede utilizarse para fraudes financieros, doxxing, chantaje, ingeniería social y otros ataques dirigidos contra las víctimas.

Las consecuencias se extienden más allá del impacto inmediato, creando un efecto dominó que puede afectar la percepción pública de la IA, ralentizar la innovación responsable y generar marcos regulatorios más restrictivos.

Estrategias y mitigaciones contra fugas de datos

01

Privacidad diferencial (DP)

Añadir ruido matemáticamente calibrado durante el entrenamiento para limitar la memorización exacta de datos sensibles, manteniendo la utilidad estadística del modelo.

03

Filtrado basado en entropía

Detectar automáticamente fragmentos con baja entropía o patrones que coincidan con formatos de datos identificables como números de teléfono o direcciones.

05

Control de acceso e inferencia

Restringir prompts excesivamente abiertos y implementar filtros que detecten intentos de extracción de memorias del modelo.

02

Filtrado y deduplicación semántica

Identificar y eliminar datos sensibles o duplicados del corpus antes del entrenamiento mediante técnicas de procesamiento de lenguaje natural y análisis semántico.

04

Machine Unlearning

Permitir la eliminación de datos específicos del modelo después del entrenamiento sin reentrenamiento completo, aunque presenta riesgos de crear nuevas vulnerabilidades.

06

Auditoría continua

Utilizar herramientas como ProPILE o MemoAnalyzer para evaluar vulnerabilidades sistemáticamente antes del despliegue y durante el ciclo de vida del modelo.

Debates éticos y dilemas contemporáneos

Tensiones fundamentales en la era de la IA

“

¿Privacidad individual vs. interés colectivo?

¿Hasta qué punto es aceptable comprometer la privacidad individual para obtener beneficios colectivos significativos en salud pública, seguridad o bienestar social? ¿Quién decide estos trade-offs?

”

“

¿Legitimidad del uso de datos públicos?

¿Es éticamente aceptable utilizar datos de redes sociales, foros públicos o sitios web para entrenar modelos comerciales sin consentimiento explícito de los usuarios? ¿Dónde trazamos la línea?

”

“

¿Explicabilidad vs. confidencialidad?

¿Cómo equilibrar la demanda de transparencia y explicabilidad en decisiones de IA con la necesidad de proteger secretos comerciales y algoritmos propietarios?

”

- ❏ **Caso práctico de debate:** ¿Debería un hospital público compartir datos anonimizados de pacientes con empresas privadas de IA para desarrollar mejores tratamientos? Considera beneficios, riesgos, consentimiento y distribución de beneficios.

Taller aplicado: Evaluación ética de IA

Actividad grupal práctica

Escenario: Sistema de IA de reconocimiento facial implementado en espacios públicos para seguridad ciudadana.

Análisis de datos recolectados

- Imágenes faciales de personas en tiempo real
- Patrones de movimiento y comportamiento
- Datos biométricos identificables
- Información de ubicación y temporal

Clasificación según AI Act

- ¿Sistema de alto riesgo o prohibido?
- ¿Requiere autorización específica?
- ¿Cumple excepciones de seguridad pública?
- ¿Necesita supervisión humana continua?

Controles según RGPD

- Base legal para el tratamiento
- Minimización y proporcionalidad
- Derechos de los afectados
- Evaluación de impacto obligatoria

Pregunta clave: ¿Es posible diseñar este sistema de manera éticamente aceptable? Si es así, ¿qué salvaguardas específicas son indispensables?



Referencias clave y recursos adicionales



Documentos regulatorios fundamentales

- [Reglamento General de Protección de Datos – Reglamento \(UE\) 2016/679](#)
- [Artificial Intelligence Act – Reglamento \(UE\) 2024/0100\(COD\)](#)



Informes y guías institucionales

- Future of Life Institute (2024). *Summary of the EU AI Act*
- [CNIL \(Francia\): IA y Protección de Datos Personales](#)
- European Data Protection Board (2021). *Guidelines on Data Protection by Design and by Default*



Literatura académica esencial

- Floridi, L. (2021). *The Ethics of Artificial Intelligence*. Oxford University Press.
- Veale, M., & Borgesius, F. Z. (2021). "Demystifying the draft EU Artificial Intelligence Act." *Computer Law Review International*.
- Mittelstadt, B. (2019). "Principles alone cannot guarantee ethical AI." *Nature Machine Intelligence*.

Estas referencias proporcionan el marco teórico y práctico necesario para comprender la intersección compleja entre privacidad, seguridad y desarrollo responsable de sistemas de inteligencia artificial en el contexto regulatorio actual.